

ENTERPRISE ARCHITECTURE

Advisor Portfolio Rebalancing & Suitability Review Platform

Low-Level Design (LLD)

Architecture Design Document

Document Version	1.0
Date	10 June 2025
Status	Draft
Classification	Confidential
Prepared By	Generated by Design Document Generator
Reviewed By	Enterprise Architecture Review Board

Document Control

This document provides the authoritative architecture design specification for the project. It is intended for consumption by architects, technical leads, and senior developers.

Version History

Version	Date	Author	Description
1.0	10 June 2025	Generated by Design Document Generator	Initial release

Table of Contents

Note: Update this table of contents after opening the document in Microsoft Word (References → Update Table).

1. Low-Level Design (LLD)
 - 1.1 API Design
 - 1.2 Database Design & Entity Model
 - 1.3 Security & Authentication Design
 - 1.4 Sequence Diagrams
 - 1.5 Error Handling Strategy
 - 1.6 Logging & Observability
 - 1.7 Caching Strategy
2. Recommended Technology Stack
3. Security & Deployment Architecture
4. Risks, Open Questions & Dependencies

1. Low-Level Design (LLD)

1.1 API Design

RESTful API design with resource-oriented endpoints, stateless JWT authentication, URL-based versioning, and consistent error handling (RFC 7807). All endpoints require authentication and enforce RBAC. Errors return HTTP status codes and structured error objects. Rate limiting is enforced at the gateway.

Base URL: /api/v1

Authentication: JWT Bearer Token issued via SSO (OIDC/SAML) and validated on each request. MFA enforced for privileged roles. All endpoints require Authorization header.

Versioning: URL versioning: all endpoints prefixed with /api/v1. Future breaking changes increment version in URL.

API Endpoints

Method	Path	Description	Authentication	Rate Limit
POST	/auth/login	Initiate SSO login and obtain JWT token.	SSO (SAML/OIDC) required	20 req/min per user
GET	/portfolios	List all portfolios assigned to the authenticated advisor.	JWT Bearer (Advisor role)	60 req/min per user
GET	/portfolios/{clientId}	Get detailed holdings and profile for a client.	JWT Bearer (Advisor role)	60 req/min per user
POST	/proposals	Create a new rebalancing proposal for a client.	JWT Bearer (Advisor role)	30 req/min per user
PUT	/proposals/{proposalId}	Edit or update a draft proposal.	JWT Bearer (Advisor role)	30 req/min per user
POST	/proposals/{proposalId}/submit	Submit proposal for suitability validation and compliance review.	JWT Bearer (Advisor role)	20 req/min per user
GET	/proposals/{proposalId}	Get suitability	JWT Bearer	30 req/min per user

Method	Path	Description	Authentication	Rate Limit
	posallId}/validation	validation report for a proposal.	(Advisor/Compliance)	user
POST	/proposals/{proposalId}/approve	Approve a proposal (Compliance Officer only).	JWT Bearer (Compliance role, MFA)	20 req/min per user
POST	/proposals/{proposalId}/reject	Reject a proposal with mandatory comment.	JWT Bearer (Compliance role, MFA)	20 req/min per user
GET	/audit	Search and filter audit log entries.	JWT Bearer (Compliance/Admin)	30 req/min per user
POST	/ai/summary	Generate AI-assisted client summary for a proposal.	JWT Bearer (Advisor role)	10 req/min per user

1.2 Database Design & Entity Model

Relational database (PostgreSQL 15) with normalized schema for users, clients, portfolios, proposals, versions, rules, and audit logs. Partitioning by client_id for scalability. Indexes on proposal_id, client_id, and timestamps. Attachments stored in object storage with DB pointers.

Database Type: Relational (PostgreSQL)

Entity Relationships

Each User can be assigned to multiple ClientProfiles. Each ClientProfile has multiple PortfolioHoldings and Proposals. Each Proposal has multiple ProposalVersions and one or more SuitabilityValidationReports. ComplianceRules are referenced by the Suitability Engine. AuditLogEntry records all actions by users on proposals, rules, and user accounts.

User

System user account with RBAC and SSO linkage.

Attribute	Type	Description	Constraints
user_id	UUID	Primary key	PRIMARY KEY
full_name	VARCHAR(100)	User's full name	NOT NULL
email	VARCHAR(255)	Unique email address	NOT NULL, UNIQUE
role	VARCHAR(32)	User role (Advisor, Compliance, etc.)	NOT NULL
is_active	BOOLEAN	Active status	DEFAULT true

Attribute	Type	Description	Constraints
sso_provider_id	VARCHAR(128)	SSO identity provider ID	
mfa_enabled	BOOLEAN	MFA enabled flag	DEFAULT false
created_at	TIMESTAMP	Creation timestamp	NOT NULL
last_login_at	TIMESTAMP	Last login timestamp	

ClientProfile

Client profile and investment preferences.

Attribute	Type	Description	Constraints
client_id	UUID	Primary key	PRIMARY KEY
full_name	VARCHAR(100)	Client name	NOT NULL
risk_profile	VARCHAR(32)	Risk profile enum	NOT NULL
investment_goals	TEXT	Goals	
time_horizon	INTEGER	Investment horizon (years)	
assigned_advisor_id	UUID	FK to User	FK → User.user_id
created_at	TIMESTAMP	Created	NOT NULL
updated_at	TIMESTAMP	Updated	

PortfolioHolding

Individual asset holdings for a client.

Attribute	Type	Description	Constraints
holding_id	UUID	Primary key	PRIMARY KEY
client_id	UUID	FK to ClientProfile	FK → ClientProfile.client_id
asset_class	VARCHAR(64)	Asset class	
security_name	VARCHAR(128)	Security name	
ticker	VARCHAR(16)	Ticker symbol	
quantity	DECIMAL(18,4)	Units held	
current_value	DECIMAL(18,2)	Market value	
current_allocation_pct	DECIMAL(5,2)	Current allocation %	
target_allocation_pct	DECIMAL(5,2)	Target allocation %	
as_of_date	DATE	Valuation date	

Proposal

Rebalancing proposal for a client.

Attribute	Type	Description	Constraints
proposal_id	VARCHAR(32)	Unique proposal ID	PRIMARY KEY, UNIQUE
client_id	UUID	FK to ClientProfile	FK → ClientProfile.client_id
advisor_id	UUID	FK to User	FK → User.user_id
status	VARCHAR(32)	Workflow status	NOT NULL
version	INTEGER	Current version	NOT NULL
created_at	TIMESTAMP	Created	NOT NULL
submitted_at	TIMESTAMP	Submitted	
resolved_at	TIMESTAMP	Approved/Rejected	
notes	TEXT	Advisor notes	
suitability_result	JSONB	Validation report	

ProposalVersion

Immutable snapshot of a proposal at each save or state change.

Attribute	Type	Description	Constraints
version_id	UUID	Primary key	PRIMARY KEY
proposal_id	VARCHAR(32)	FK to Proposal	FK → Proposal.proposal_id
version_number	INTEGER	Version number	NOT NULL
allocations_snapshot	JSONB	Asset allocations	NOT NULL
saved_by	UUID	User who saved	FK → User.user_id
saved_at	TIMESTAMP	Save timestamp	NOT NULL

SuitabilityValidationReport

Result of suitability validation for a proposal version.

Attribute	Type	Description	Constraints
report_id	UUID	Primary key	PRIMARY KEY
proposal_id	VARCHAR(32)	FK to Proposal	FK → Proposal.proposal_id
version_id	UUID	FK to ProposalVersion	FK → ProposalVersion.version_id
run_at	TIMESTAMP	Validation time	NOT NULL
overall_result	VARCHAR(32)	Pass/Fail/Warning	NOT NULL
violations	JSONB	List of violations	

ComplianceRule

Configurable suitability rule.

Attribute	Type	Description	Constraints
rule_id	UUID	Primary key	PRIMARY KEY
rule_name	VARCHAR(128)	Rule name	NOT NULL
risk_profile_target	VARCHAR(32)	Target risk profile	
asset_class	VARCHAR(64)	Asset class	
operator	VARCHAR(8)	Comparison operator	
threshold_pct	DECIMAL(5,2)	Threshold %	
severity	VARCHAR(16)	Critical/Warning	NOT NULL
is_active	BOOLEAN	Active flag	DEFAULT true
modified_by	UUID	User who modified	FK → User.user_id
modified_at	TIMESTAMP	Modification time	NOT NULL

AuditLogEntry

Immutable audit trail of all actions.

Attribute	Type	Description	Constraints
log_id	UUID	Primary key	PRIMARY KEY
timestamp_utc	TIMESTAMP	UTC timestamp	NOT NULL
user_id	UUID	FK to User	FK → User.user_id
user_role	VARCHAR(32)	Role at time of action	
action_type	VARCHAR(64)	Action performed	NOT NULL
entity_type	VARCHAR(64)	Entity affected	
entity_id	VARCHAR(64)	Entity ID	
previous_state	VARCHAR(64)	Previous state	
new_state	VARCHAR(64)	New state	
source_ip	VARCHAR(45)	Source IP address	
session_id	VARCHAR(64)	Session ID	

Entity Relationship Diagram

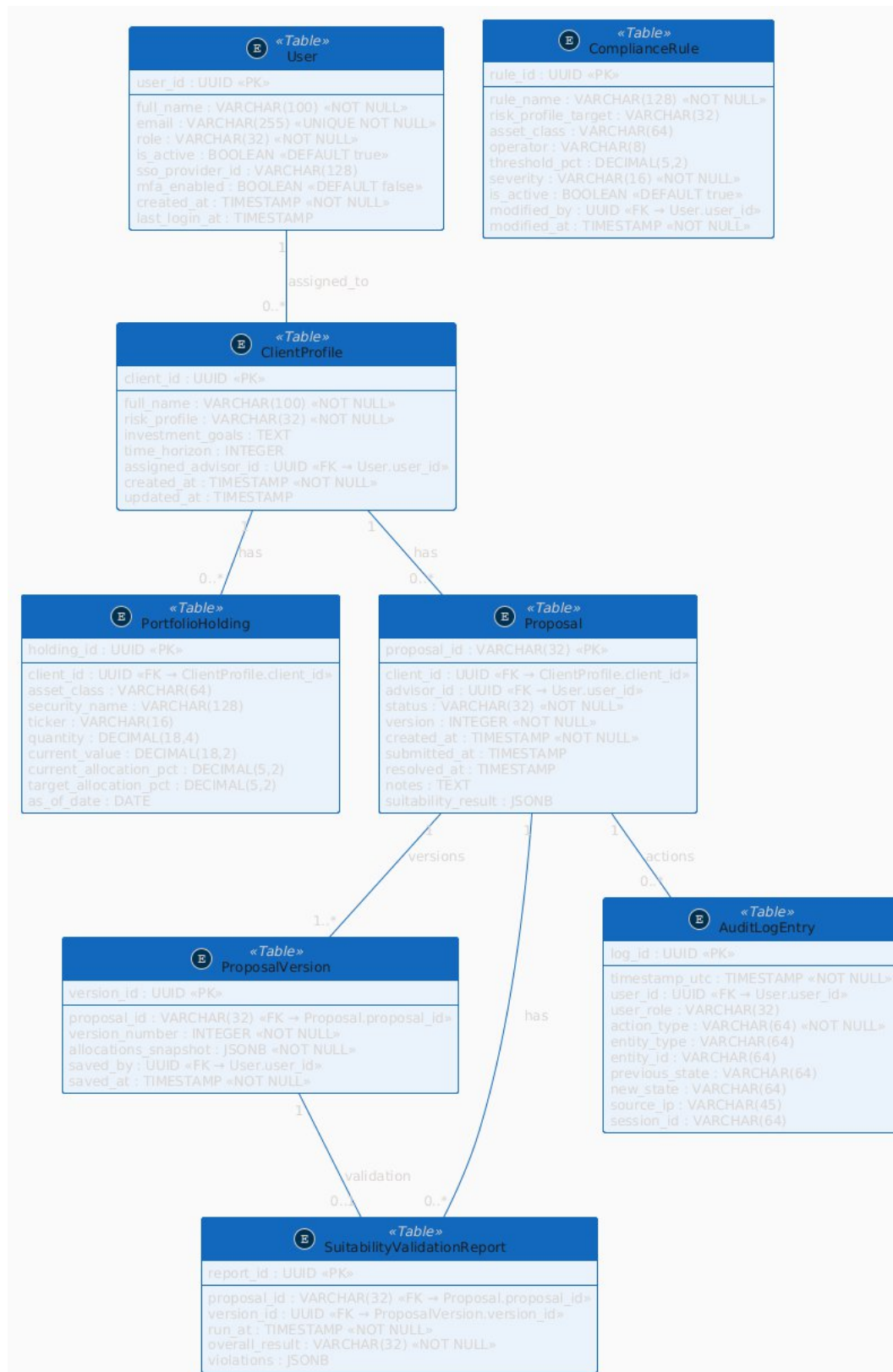


Figure: Entity Relationship Diagram

1.3 Security & Authentication Design

Authentication: SSO via SAML 2.0 or OIDC (OAuth 2.0), with JWT Bearer tokens for API access. MFA enforced for Compliance and Admin roles. Session expiration after 30 minutes inactivity, with warning at 28 minutes.

Authorisation Model: Role-Based Access Control (RBAC) with four roles: Financial Advisor, Compliance Officer, Operations, System Admin. Each role has a defined, non-overlapping permission set. All endpoints check JWT claims for role and permissions.

Data Encryption: All data at rest encrypted with AES-256 (PostgreSQL TDE, S3 SSE). All data in transit encrypted with TLS 1.3. No plaintext PII stored.

Network Security: WAF with OWASP ruleset, DDoS protection, private subnets for data tier, firewall rules restricting access, VPN for admin access, no public DB endpoints.

Security Controls

- OWASP Top 10 mitigations
- Input validation and sanitization on all user input
- CSRF protection for all state-changing endpoints
- XSS protection via frontend encoding and CSP
- Strict RBAC enforcement at API and UI layers
- Audit logging of all privileged actions
- Rate limiting and brute-force protection at gateway
- Secrets management via Key Vault
- Regular vulnerability scanning and patching
- Automated session expiration and revocation
- MFA for privileged roles
- Encryption of all sensitive data at rest and in transit

Compliance Standards

- GDPR
- ISO 27001
- SOC 2 Type II

1.4 Sequence Diagrams

1. User Authentication Flow

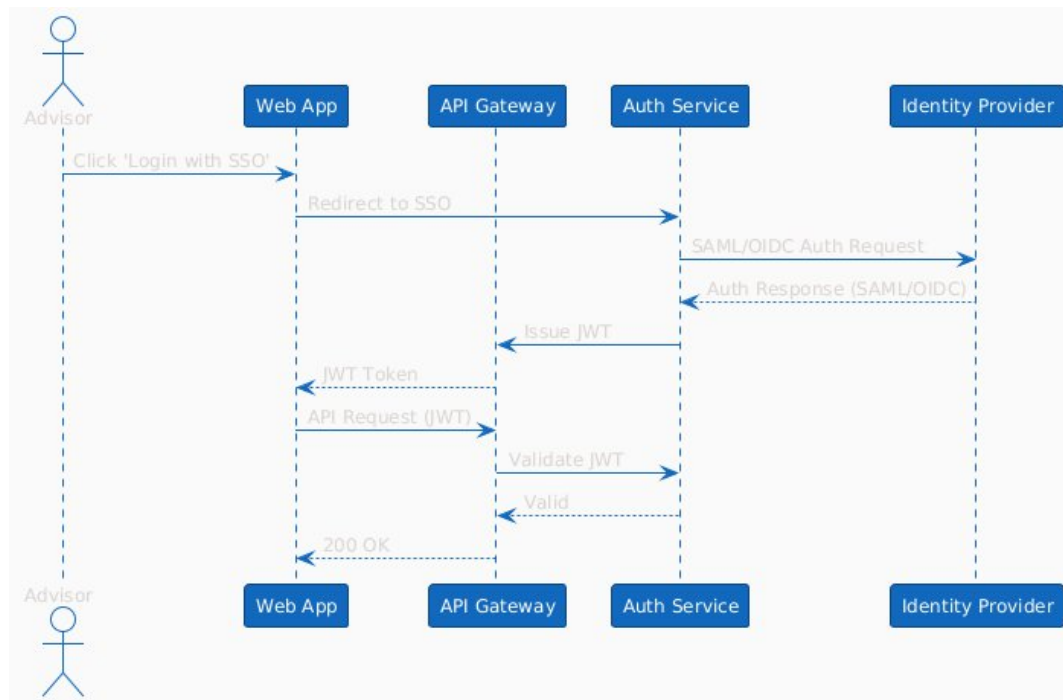


Figure: User Authentication Flow

2. Core Business Flow

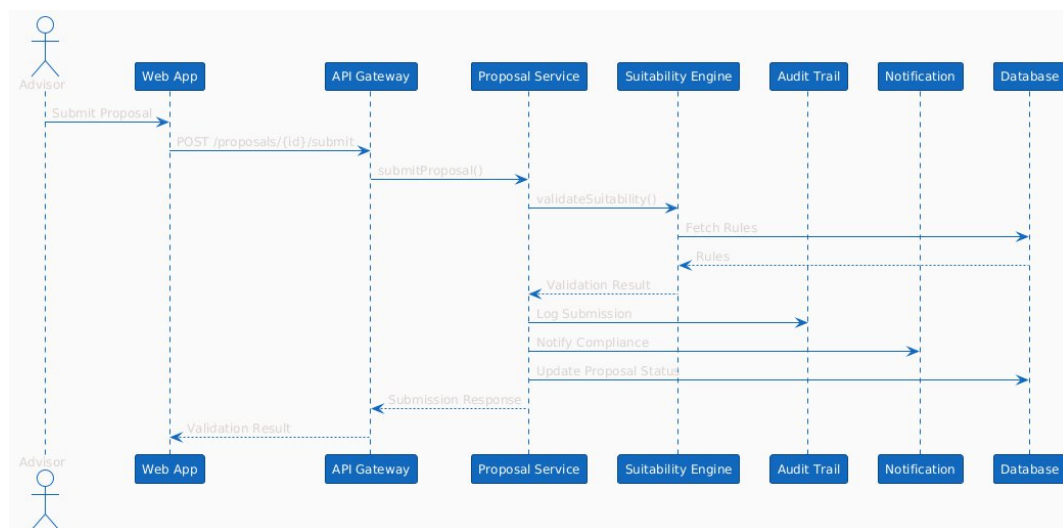


Figure: Core Business Flow

3. Error Handling and Retry Flow

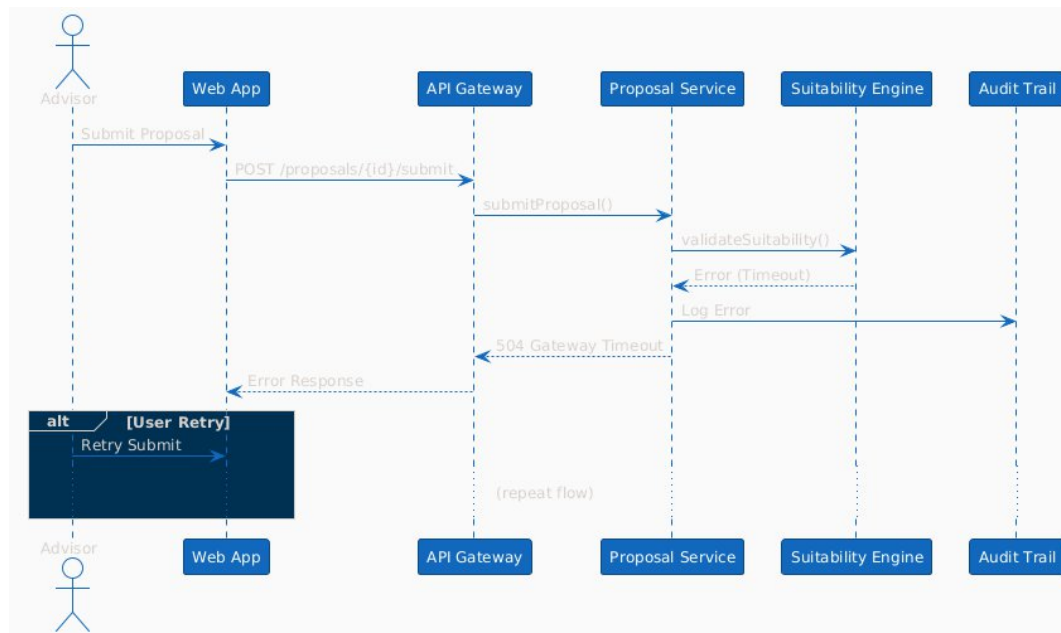


Figure: Error Handling and Retry Flow

1.5 Error Handling Strategy

All API errors return RFC 7807 Problem Details objects. User-facing errors are actionable and non-technical. Retry logic for transient errors (e.g., AI summary, validation) with exponential backoff. Circuit breakers on external integrations. Dead-letter queue for failed notifications. All errors logged with correlation IDs.

1.6 Logging & Observability

Structured JSON logging at all layers. Log levels: ERROR, WARN, INFO, DEBUG. Correlation IDs propagated via headers. Logs retained for 90 days (app), 7 years (audit). Integrated with SIEM (Azure Monitor/Grafana). Sensitive data redacted.

1.7 Caching Strategy

Redis L1 cache for portfolio/proposal reads (TTL 5 min). L2 cache for suitability rules (TTL 1 hour). Cache invalidation on proposal update or rule change. No caching of PII in browser/local storage.

2. Recommended Technology Stack

The following technology stack is recommended based on the analysed requirements, industry best practices, and enterprise standards.

5.1 Frontend

Technology	Version	Purpose	Rationale
React	18	SPA frontend	Modern, component-based, widely adopted
TypeScript	5.x	Type safety	Reduces runtime errors
Material UI	5.x	UI components	Consistent, accessible UI

5.2 Backend

Technology	Version	Purpose	Rationale
Node.js	20.x	API and services	Scalable, async, large ecosystem
Express	4.x	REST API framework	Lightweight, flexible
TypeORM	0.3.x	ORM	Type-safe DB access

5.3 Database

Technology	Version	Purpose	Rationale
PostgreSQL	15	Relational data store	ACID, strong consistency, compliance

5.4 Messaging

Technology	Version	Purpose	Rationale
Redis	7	Cache, pub/sub	Low-latency caching, ephemeral data

5.5 Infrastructure

Technology	Version	Purpose	Rationale
Kubernetes (AKS/EKS)	1.29	Container orchestration	Scalability, HA, cloud-native
NGINX/Kong	3.x	API gateway	Security, routing, rate limiting
Azure Blob/AWS S3	N/A	Object storage	Durable, encrypted file storage

5.6 DevOps & CI/CD

Technology	Version	Purpose	Rationale
GitHub Actions	N/A	CI/CD pipeline	Automation, integration
Docker	24.x	Containerization	Portability, reproducibility

5.7 Monitoring & Observability

Technology	Version	Purpose	Rationale
Azure Monitor	N/A	Metrics/logs	Cloud-native, alerting
Grafana	10.x	Dashboards	Visualization, observability

5.8 Security

Technology	Version	Purpose	Rationale
Azure Key Vault	N/A	Secrets management	Centralized, auditable
OWASP CRS	3.x	WAF ruleset	Mitigate common web threats

3. Security & Deployment Architecture

3.1 Deployment Architecture

The platform is deployed on a cloud-native Kubernetes cluster (AKS/EKS) in a primary region, with a standby DR region for failover. All ingress passes through a managed load balancer with WAF and DDoS protection. Application pods are deployed in private subnets, with network policies restricting east-west traffic. Data tier (PostgreSQL, Redis, Blob) is isolated in a private subnet with no public endpoints. Secrets are managed via Azure Key Vault. Monitoring and logging are centralized. High availability is achieved via multi-AZ deployments, auto-scaling, and health probes. All traffic is encrypted (TLS 1.3). Disaster recovery is enabled via geo-replication and automated backups. The architecture supports horizontal scaling and zero-downtime deployments.

3.2 Deployment Diagram

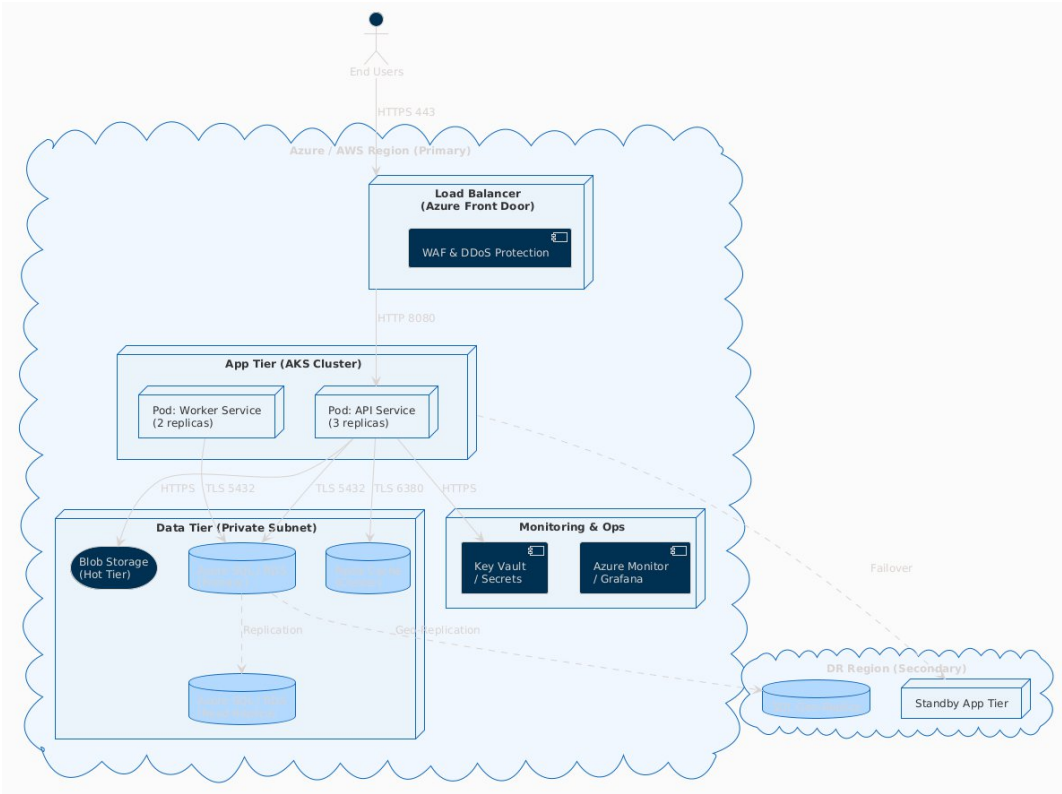


Figure: Deployment Architecture

3.3 Environment Strategy

Environment	Description	Infrastructure	URL
Development	Dev/test environment with seeded data, relaxed security, and debug logging.	Cloud (AKS/EKS, small nodes)	dev.example.com

Environment	Description	Infrastructure	URL
Staging	Pre-production, full NFRs, production-like data and security.	Cloud (AKS/EKS, medium nodes)	staging.example.com
Production	Live environment, full HA, DR, and compliance controls.	Cloud (AKS/EKS, multi-AZ, HPA)	example.com

3.4 Containerisation & Orchestration

Containerisation: All services packaged as Docker images. Multi-stage builds for minimal images. Images stored in private registry (ACR/ECR). Base images are official Node.js/Alpine, scanned for vulnerabilities.

Orchestration: Kubernetes namespaces per environment. Resource quotas and limits per pod. HPA for API and worker pods. Pod disruption budgets for HA. Rolling updates and blue/green deployments.

3.5 CI/CD Pipeline

Pipeline: code commit → static analysis → unit tests → build Docker image → integration tests → security scan → deploy to staging → E2E tests → manual approval → production deploy.

3.6 Scalability & Performance

Scalability Strategy: Horizontal scaling via HPA. Load balancer distributes traffic. Redis for caching. CDN for static assets. DB read replicas for reporting.

Performance Considerations: SLA: 95th percentile API <500ms, page load <3s. Load testing with JMeter. Bottlenecks mitigated via caching, DB indexing, async processing.

3.7 Disaster Recovery

RTO: 4 hours, RPO: 15 minutes. Automated DB and blob backups. Geo-replication to DR region. Failover tested quarterly.

3.8 Security Measures

- TLS 1.3 everywhere
- WAF with OWASP ruleset
- Secrets management (Azure Key Vault)
- MFA for privileged roles
- RBAC at API and cluster level
- Private subnets for data tier
- No public DB endpoints

- Audit logging of all privileged actions
- Automated vulnerability scanning
- DDoS protection at edge
- Session expiration and revocation
- Regular penetration testing

4. Risks, Open Questions & Dependencies

The following risks, open questions, and dependencies have been identified. All items should be tracked and resolved before the design is finalised.

ID	Category	Description	Impact	Probability	Mitigation	Owner
R1	Risk	Mock data may not reflect real portfolio complexity, limiting suitability engine validation.	High	Medium	Define representative mock data; review with compliance.	Product Owner
R2	Risk	Simplified compliance rules engine may not capture all regulatory nuances.	High	High	Document simplifications; plan Phase 2 upgrade; compliance sign-off.	Compliance Officer
R3	Risk	AI summary quality may be inconsistent for edge-case portfolios.	Medium	Medium	Human editing step; prompt engineering; track edit rates.	Product Owner
R4	Dependency	SSO integration delays with firm's IdP may block end-to-end testing.	High	Medium	Implement local login fallback for non-prod; engage IdP team early.	Tech Lead
R5	Risk	Audit log volume may exceed storage projections at scale.	Medium	Low	Size storage for 7 years; implement archiving for logs >1 year.	DevOps
R6	Risk	Scope creep from stakeholders requesting real-time market data during MVP.	Medium	High	Maintain out-of-scope list; formal change control.	Product Manager